

BÁO CÁO DỰ ÁN:
PHÁT HIỆN TẤN CÔNG BRUTE-FORCE RDP
VÀ QUY TRÌNH ỨNG PHÓ SỰ CỐ SỬ DỤNG
SPLUNK

Tác giả: Đỗ Hữu Trung
Ngày hoàn thành: 15/08/2026

1. TÓM TẮT SỰ CỐ (Executive Summary)

Vào ngày 14/08/2026, một cuộc tấn công brute-force vào giao thức Remote Desktop Protocol (RDP) đã được phát hiện trên máy tính nạn nhân DESKTOP-IUKE6AK. Kẻ tấn công sử dụng máy Kali Linux để thực hiện tấn công.

Kết quả điều tra:

- Hacker đã thực hiện hơn 50 lần đăng nhập thất bại trong vòng 2 phút.
- Tấn công thành công với tài khoản trungdh và mật khẩu 123456.
- Sau khi đăng nhập, hacker đã copy file hacked.txt vào máy nạn nhân và xóa Logs
- SOC đã phát hiện sự cố, điều tra và xử lý thành công.

2. MÔ TẢ SỰ CỐ (Incident Description)

2.1. Thông tin chung:

- Thời gian tấn công: 14/08/2026, 08:39:00 – 08:49:00
- Thời gian phát hiện và khắc phục sự cố: 14/08/2026, 10:04:00 – 10:20:00
- Máy tấn công: Kali Linux
- Hệ thống bị ảnh hưởng: Máy nạn nhân DESKTOP-IUKE6AK (Windows 10 Pro)
- IP nạn nhân: 192.168.188.129
- IP kẻ tấn công: 192.168.188.128
- Phương thức tấn công: brute-force RDP
- Công cụ sử dụng để tấn công: Nmap, Hydra,...
- Công cụ sử dụng để điều tra, khắc phục sự cố: Splunk
- Mức độ nghiêm trọng: Cao (truy cập trái phép)

2.2. Môi trường lab

- Máy tấn công:

- + Hệ điều hành: Kali Linux
- + Hostname: trung
- + IP: 192.168.188.128
- + Công cụ: Nmap, Hydra

- Máy nạn nhân:

- + Hệ điều hành: Windows 10 Pro
- + Hostname: DESKTOP-IUKE6AK
- + IP: 192.168.188.129
- + Công cụ: RDP Host, Splunk UF

- Máy của SOC Analyst:

- + Hệ điều hành: Windows 11
- + Hostname: TrungDH
- + IP: 192.168.188.1
- + Công cụ: Splunk Enterprise

- Mạng: Host-Only (VMware VMnet1, 192.168.188.0/24)

3. QUÁ TRÌNH ĐIỀU TRA (Investigation Process)

3.1. Thu thập log

- Kiểm tra Splunk Forwarder đã nhận log từ máy nạn nhân chưa.
- Xác nhận dữ liệu đã về Splunk.
- Truy vấn kiểm tra:

index=main

| stats count by host

Kết quả: host=DESKTOP-IUKE6AK

3.2. Phát hiện bất thường

a) Tìm sự kiện đăng nhập thành công (EventCode 4624)

- Truy vấn SPL:

```
index=main EventCode=4624  
| table _time, Logon_Type, ComputerName  
| sort - _time
```

Kết luận:

- + Logon_Type=10: Đăng nhập qua RDP (RemoteInteractive).
- + Logon_Type=3: Đăng nhập qua mạng (Network).

b) Xác định IP của hacker (từ đăng nhập thành công)

Truy vấn SPL:

```
index=main EventCode=4624 ComputerName="DESKTOP-IUKE6AK"  
| table _time, Logon_Type, ComputerName, src_ip  
| sort - _time
```

Kết luận:

- + Phát hiện 2 sự kiện đăng nhập thành công:
 - Logon_Type=3 (Network) → Có thể từ Hydra.
 - Logon_Type=10 (RDP) → Xác nhận hacker đã đăng nhập bằng RDP.
- + IP nguồn: 192.168.188.128 (Kali).

c) Phát hiện brute-force (nhiều lần đăng nhập thất bại)

Truy vấn SPL:

```
index=main EventCode=4625  
| table _time, EventCode, Logon_Type  
| sort - _time
```

Kết luận:

- + Có 50 sự kiện đăng nhập thất bại (4625) trong khoảng 2 phút.
- + Đây là dấu hiệu của tấn công brute-force.

d) Kiểm tra log có bị xóa không (EventCode 1102)

Truy vấn SPL:

```
index=main EventCode=1102
```

Kết luận:

- + Phát hiện sự kiện Security Log bị xóa.
- + Hacker đã xóa log sau khi thực hiện các thao tác.

3.2. Giai đoạn 2: Phân tích sâu trên máy nạn nhân

Mở Command Prompt

B1. Kiểm tra tiến trình lạ:

Chạy lệnh: tasklist /v

=> Không phát hiện tiến trình bất thường đang chạy.

B2. Kiểm tra kết nối mạng:

Chạy lệnh: netstat -anob

=> Không phát hiện kết nối lạ đang hoạt động.

B3. Kiểm tra file hệ thống:

Chạy lệnh: dir C:\Users\trungdh\Documents\

=> Phát hiện file hacked.txt với nội dung: *"Máy nạn nhân đã bị hack"*

=> Xóa file hacked.txt

4. PHÂN TÍCH CHI TIẾT (Detailed Analysis)

4.1. Phân tích hành vi tấn công

Thời gian	Hành động	Bằng chứng
08:39:00	Hacker quét mạng	Nmap scan: 192.168.188.0/24
08:41:00	Phát hiện cổng 3389 mở	Nmap: 3389/tcp open ms-wbt-server
08:44:00	Brute-force RDP	Hydra: thử với file 100 passwords phổ biến
08:45:00	Đăng nhập thành công	EventCode 4624, Logon_Type=10
08:47:00	Copy file hacked.txt	Path: C:\Users\trungdh\Documents\
08:48:00	Xóa Security Log	EventCode 1102
08:48:50	Đăng xuất	Lệnh logoff

4.2. Phân tích điểm yếu

- Mật khẩu yếu: Tài khoản trungdh sử dụng mật khẩu 123456 - đây là mật khẩu phổ biến và dễ bị brute-force.
- NLA (Network Level Authentication) chưa bật: Cho phép hacker gửi yêu cầu xác thực mà không cần thiết lập phiên RDP.
- Account Lockout Policy chưa bật: Không giới hạn số lần đăng nhập sai, tạo điều kiện cho brute-force.
- Thiếu giám sát log: Không có cảnh báo (alert) khi phát hiện nhiều lần đăng nhập thất bại.

4.3. Phân tích dấu vết của hacker

Dấu vết	EventCode	Logon_Type	Giải thích
Brute-force	4625	3 (Network)	Hydra thử mật khẩu qua mạng
Đăng nhập thành công	4624	3 (Network)	Hydra tìm đúng mật khẩu
RDP Login	4624	10	Hacker đăng nhập qua RDP
Log xóa	1102	-	Security Log bị xóa

5. KẾT QUẢ VÀ BẰNG CHỨNG (Findings & Evidence)

5.1. Bảng chứng thu thập được

STT	Bằng chứng	Mô tả
1	IP 192.168.188.128	IP của máy tấn công
2	User trungdh	Tài khoản bị hack
3	File hacked.txt	Path: C:\Users\trungdh\Documents\hacker.txt
4	EventCode 4625 (>50 lần)	Brute-force RDP
5	EventCode 4624 (2 lần)	Đăng nhập thành công
6	EventCode 1102 (1 lần)	Security Log bị xóa
7	Screenshot Splunk	Phát hiện 4625, 4624, 1102

6. XỬ LÝ VÀ KHẮC PHỤC SỰ CỐ (Incident Response)

Bước	Hành động	Người thực hiện	Thời gian
1	Cách ly máy nạn nhân khỏi mạng	SOC Analyst	10:10:00
2	Đổi mật khẩu user trungdh	SOC Analyst	10:11:00
3	Xóa file hacked.txt	SOC Analyst	10:16:00
4	Kiểm tra tài khoản lạ	SOC Analyst	10:18:00
5	Chặn IP 192.168.188.128 trên Firewall	SOC Analyst	10:20:00

7. BÀI HỌC KINH NGHIỆM (Lessons Learned)

7.1. Điểm yếu của hệ thống

- Mật khẩu yếu: bị bẻ khóa thành công với file mật khẩu phổ biến
- Không giới hạn số lần login sai: tạo điều kiện cho brute-force
- Thiếu giám sát: phát hiện tấn công muộn, sau khi hacker đã rời đi

7.2. Biện pháp khắc phục dài hạn

- Chính sách mật khẩu: Áp dụng mật khẩu mạnh (tối thiểu 8 ký tự, bao gồm chữ hoa, chữ thường, số, ký tự đặc biệt).
- Bật Account Lockout Policy: Cấu hình khóa tài khoản sau nhiều lần đăng nhập sai.
- Bật Alert trên Splunk: Cảnh báo khi phát hiện nhiều đăng nhập thất bại liên tiếp.
- Cập nhật thường xuyên: Đảm bảo hệ thống được vá lỗi bảo mật định kỳ.

7.2. Bài học từ quá trình điều tra

- Công cụ: Splunk giúp phát hiện tấn công
- Dấu vết không chỉ có log: Khi log bị xóa, cần kiểm tra trực tiếp trên máy nạn nhân.
- Phát hiện sớm: Giám sát EventCode 1102 (log xóa) là dấu hiệu quan trọng.
- Quy trình IR rõ ràng: Phát hiện → Điều tra → Ứng phó → Báo cáo.

8. KẾT LUẬN (Conclusion)

Sự cố tấn công brute-force RDP đã được phát hiện, điều tra và xử lý thành công. Kẻ tấn công đã truy cập trái phép vào máy nạn nhân nhưng không gây ra thiệt hại nghiêm trọng.

Các điểm chính:

- Phát hiện tấn công brute-force qua Splunk.
- Xác định IP của kẻ tấn công (192.168.188.128).
- Xác nhận đăng nhập thành công và xóa log.
- Xóa file độc hại và khôi phục hệ thống.
- Áp dụng các biện pháp phòng ngừa.